Task 3: Perform a Basic Vulnerability Scan on Your PC.

Vulnerability Scanning.

- **With Nmap scripting engine (NSE), we can perform DNS enumeration, OS fingerprinting, vulnerability detection, malware discovery and many other tasks.**

Although NSE has its advantages, it also has disadvantages when compared to vulnerability scanners:

- **NSE is not fully comprehensive, meaning many vulnerabilities are not covered.**
- **NSE cannot perform a large number of scans simultaneously.**
- **NSE is most efficient when performing single host scans.**
- **NSE is most useful when doing basic information gathering or enumeration activities.**
- **Vulnerability scanners can help make up for many of the limitations of NSE.**

Vulnerability testing often gets confused with penetration testing. While similar, they have distinct differences:

- **Vulnerability scanning identifies systems that have known vulnerabilities.**

  - **Scans use a database of known vulnerabilities.**
  - **Vulnerabilities are rated based on the severity level.**
  - **Vulnerabilities are given a Common Vulnerability Scoring System (CVSS) score.**
- **Penetration testing attempts to identify weaknesses that can be exploited, such as:**
  - **Specific system configurations**
  - **Organizational processes and practices**

For these reasons, vulnerability scanning is often more found during security audits rather than penetration tests. Unfortunately, companies often do not understand the differences between the two and sometimes think a vulnerability scan passes as a penetration test when they're actually very different.

Vulnerability Scanning and Nessus

A vulnerability scanner, such as Nessus, is an application that identifies vulnerabilities and creates inventory of all interconnected systems. These include the following:

- **Servers**
- **Desktops**
- **Laptops**
- **Virtual machines**
- **Containers**
- **Firewalls**
- **Switches**
- **Printers**

Most vulnerability scanners attempt to log into systems using default passwords or other credentials in order to establish a more detailed picture of the network infrastructure.

After establishing an inventory list, the vulnerability scanner checks each item in its inventory against one or more databases of known vulnerabilities to see which items are associated with specific threats.

Nessus Vulnerability Scanning

Nessus is one of many vulnerability scanners available today. It is used to perform vulnerability assessments and penetration tests, in addition to malicious attacks.

- **Other popular vulnerability scanners are:**

- **OpenVAS: A fully featured, freely available open source vulnerability scanner sharing many of the same capabilities as Nessus. It comes preinstalled with Kali Linux.**

- **Nexpose: A vulnerability scanner developed by Rapid7 that comes fully integrated with Metasploit. It's sold as a stand-alone software package that can also be used as a managed service or private cloud deployment.**

The National Vulnerability Database (NVD) is a source of exploit information that grades each vulnerability based on its severity level.

- **For example, if you google NIST CVE-2016-0800, you will find the nvd.nist.gov webpage, which provides details, references, and a score of 5.9.**

- **Severity levels are scored using the Common Vulnerability Scoring System (CVSS v3.0).**

Numerical scores are translated into qualitative categories (low, medium, high, and critical), to help security administrators properly assess and prioritize vulnerabilities.

We will use Nessus to demonstrate how to perform scans and interpret the results.

1. **First, we'll start Nessus via the command line:**

Run /etc/init.d/nessusd start

2. **Launch the Firefox browser and navigate to https://kali:8834.**

Since this is not a real website, Firefox will inform us that our connection is insecure.

Click Advanced.

Click Add Exception.

Click Confirm Security Exception.

Log in:

Note: When logging in for the first time, it can take up to two minutes while the Nessus Scanner is compiling plugins.



3. **After the program launches, we're presented with the Scan page.**

The Nessus user interface is made up of two main parts:

The Scan page, where we can set up scans.

The Settings page, where we can manage application configuration settings.

4. **There are two scan types:**

Credentialed scans use appropriate privileges and provide a more accurate view of risks. Downsides include a high number of false positives and high bandwidth usage.

The reason for the high false positives count is that there are a lot of different versions and packaging for any number of services you may download. Because of this, Nessus will flag a service that it is unsure about to avoid false negatives.

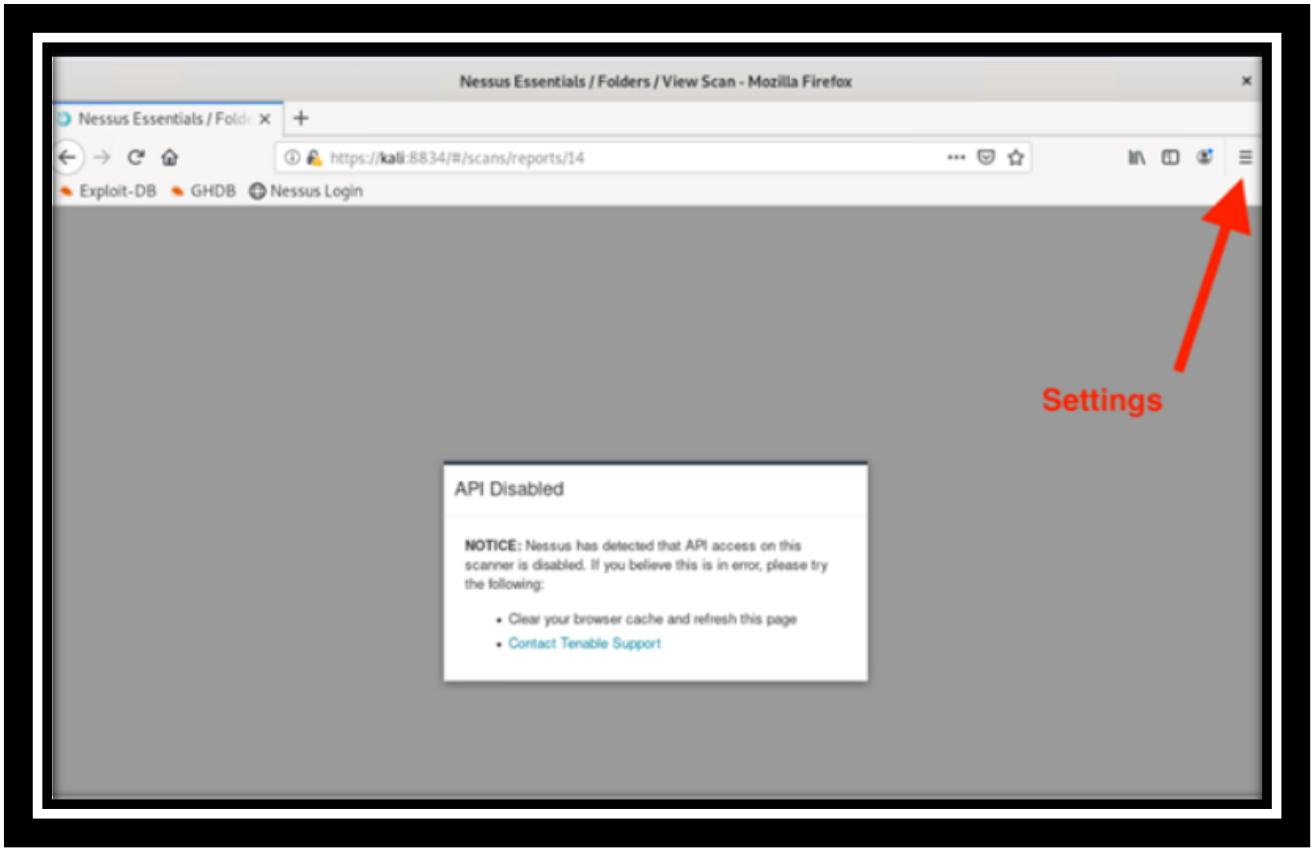
Credentialed scans often finish more quickly than uncredentialed scans due to reduced back-and-forth communication checks between the scanner and its target.

Uncredentialed scans enumerate system service and version numbers on open listening ports, then perform a vulnerability check against a known list of associated exploits.

During an audit, it's common that the customer will give the auditors credentials to machines so they can perform credential scans. The scan in this example is not credentialed and will only show the ports and their services.

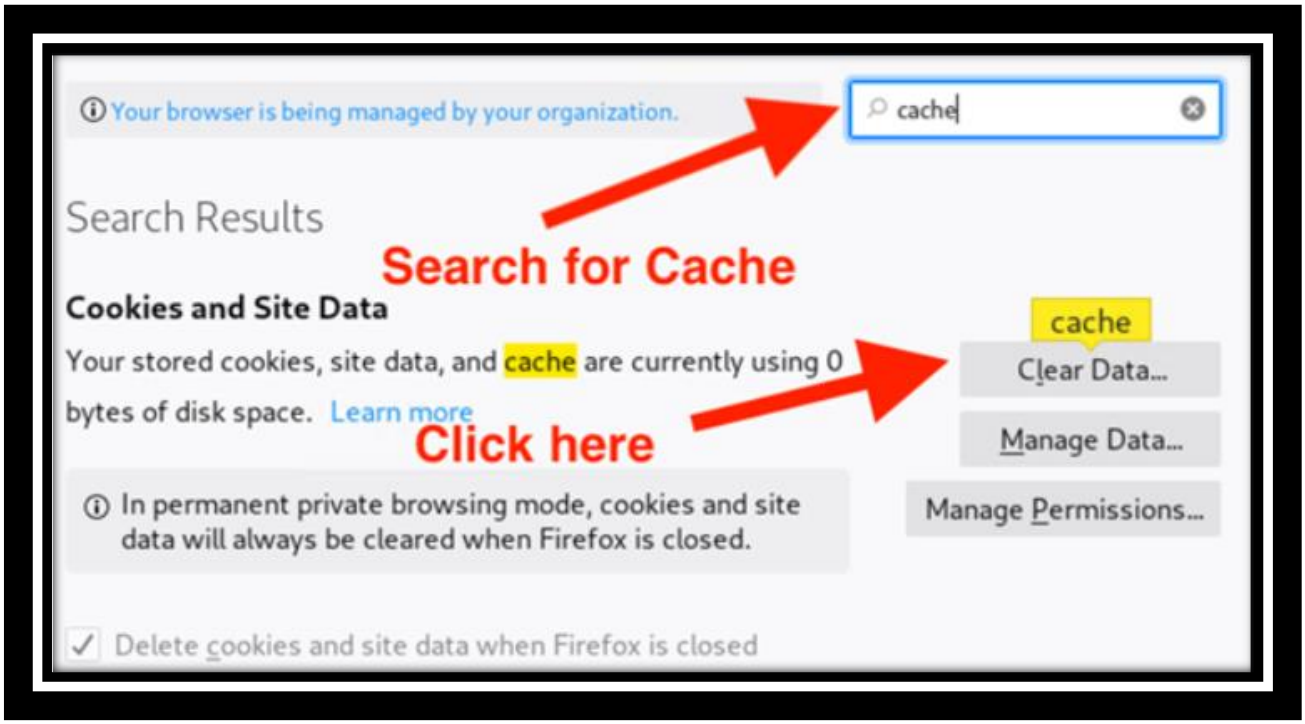
5. **Double-click on the scan My Basic Network Scan to open the scan overview.**

Note: If you see the following error, note that we are not using APIs with our scanner, but we can troubleshoot this easily.



Open a new browser window and navigate to Firefox's settings. In the upper-right-hand corner search bar, search for "cache." Click on Clear Data and

return to the Scans page in Nessus. Refresh the page and continue.

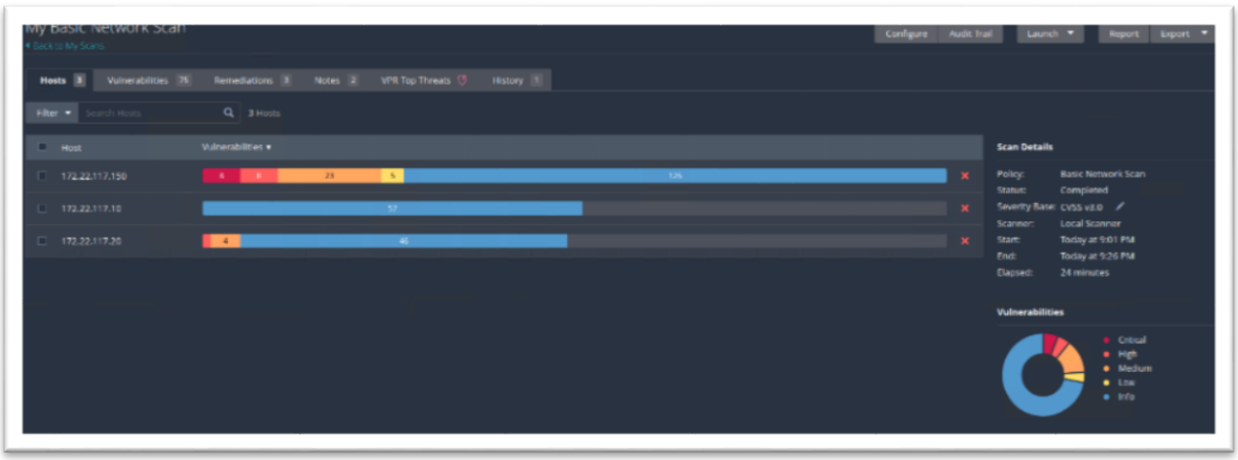


Returning to the Scans page in Nessus, note that we can see several useful pieces of information:

Scan progress, which in this case is "Completed."

A bar graph displaying the number of vulnerabilities at each severity level.

A pie chart showing severity levels.



6. **Click on the Vulnerabilities tab.**

Nessus assigns all vulnerabilities to a specific severity level based on the National Vulnerabilty Database or NVD CVSSv3 score as follows:

Critical: 9.0 - 10.0

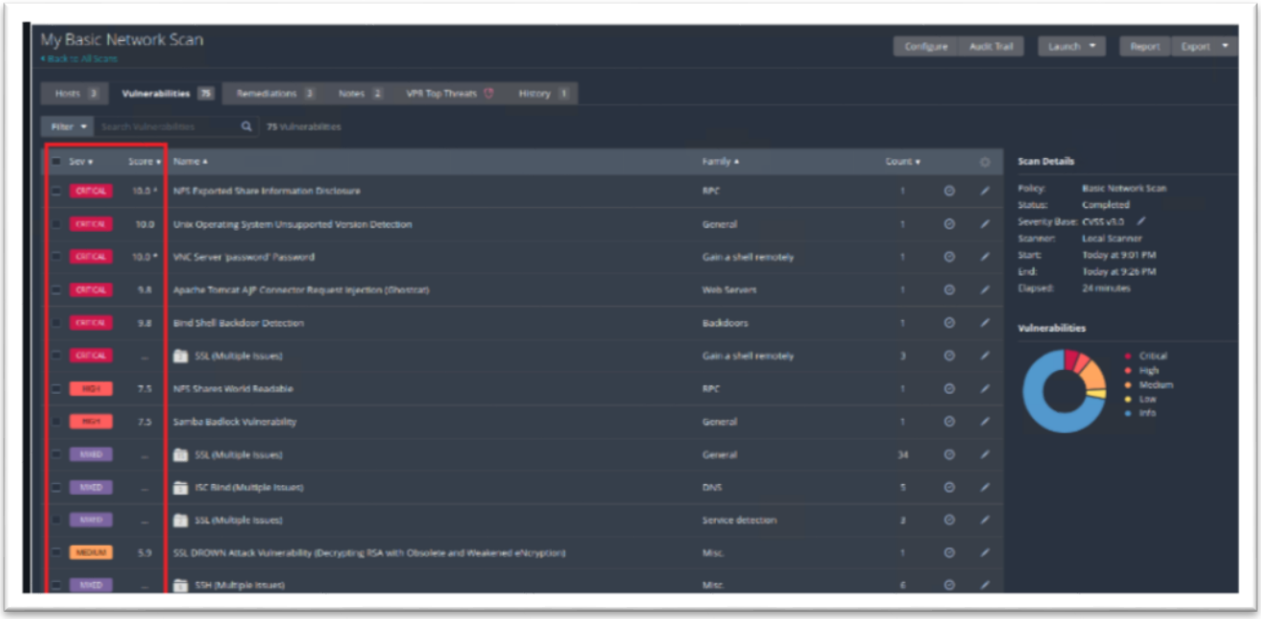
High: 7.0 - 8.9

Medium: 4.0 - 6.9

Low: 0.1 - 3.9

None: 0

Note: Vulnerabilities classified as "None" aren't necessarily actual vulnerabilities. These can just be additional information that may be useful to an attacker.

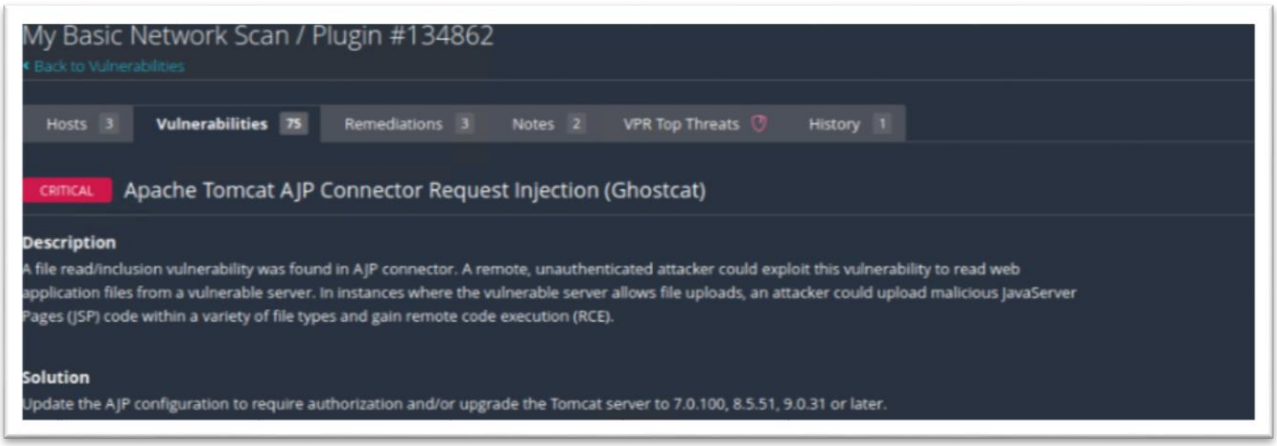


7. **Clicking on individual vulnerabilities will display specific details about that vulnerability.**

Click on the critical vulnerability listed toward the top of the list: Apache Tomcat AJP Connector Request Injection (Ghostcat)

Nessus detected a code injection vulnerability by performing an port scan, finding the version of the running service, then performed a CVE lookup in the background.

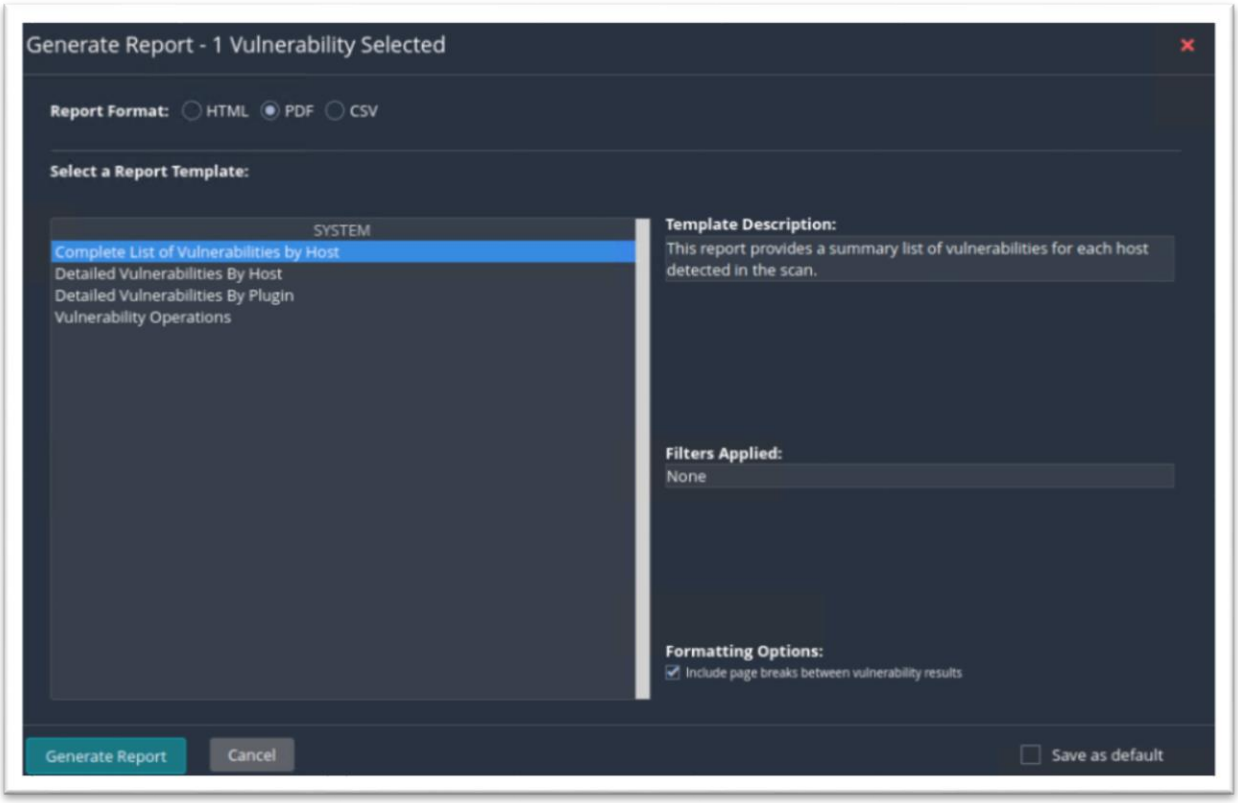
Nessus combines multiple functions into one, which is one of the advantages of using Nessus.



8. **Auditors will typically include vulnerability scan reports in their assessments. Nessus also has the report generating capabilities.**

Click on Report in the top right corner.

In the popup, select PDF and 'Complete List of Vulnerabilities by Host'. Then click Generate Report.



This will create a PDF version of the scan results that includes a customizable executive summary.

While vulnerability scans may seem comprehensive, they often have some issues:

9. **False positives are common in vulnerability scanners. It's up to the individual performing the scan to check their validity with other tools.**

10. **Severity scores are heavily subjective. For example, a CVSS score 8 vulnerability on a machine with a public IP address would always take priority over a CVSS score 10 vulnerability on a private machine due to the higher risk of an attack since it's accessible from the public internet.**

A vulnerability scanner's essentially compares an indepth port scan to a list of CVEs. It cannot chain attacks together or verify with 100% accuracy if a vulnerability does exist. This is where a penetration tester comes in.

- **Summary**

Nessus is a free open-source network vulnerability scanner that uses the Common Vulnerabilities and Exposures database to correlate security compliance with specific security threats.

Nessus discovers vulnerabilities that malicious hackers can exploit to breach a network, and generates reports.

Vulnerability scans search for known vulnerabilities in a system and report potential exposures.

Penetration tests exploit weaknesses in network infrastructure to determine the level at which a malicious actor can gain unauthorized access.

Vulnerability scans are typically automated.

Penetration tests are manual tests performed by a security professional, thus vulnerability scanning is not common in actual penetration tests.

While we will not use Nessus beyond this lesson, it is important for you to know that vulnerability scanning and vulnerability management are common first jobs in security and are often a gateway into penetration testing.